AI for Inclusive Education
Flaw Detection & Improvement Report

Offline Smart Learning Assistant | Technical review generated 7 November 2026

Scope: Review of the repository's security, reliability, architecture, claims, retrieval quality, testing, and deployment behavior. Findings are based on source inspection and the existing test suite.

Executive summary

The existing tests pass, but they do not cover the highest-risk issues. The most urgent work is to secure file upload and training endpoints, prevent unsafe checkpoint loading and path traversal, and correct the retrieval abstention and confidence logic. The project should also clearly distinguish the local offline application from the hosted Vercel demo.

Findings

CRITICAL / HIGH **Unauthenticated upload and model training**

Anyone who can reach the endpoint can upload files and trigger expensive PyTorch training, creating a denial-of-service risk.

Evidence: api/index.py:118-247; gui_server.py:888-950
Improve by: Add authentication, upload-size limits, MIME/PDF validation, rate limiting, request timeouts, and a bounded background job queue.

CRITICAL / HIGH **Arbitrary model output path**

Training endpoints accept a caller-controlled save path and may overwrite files outside the intended model directory.

Evidence: gui_server.py:980-1044
Improve by: Accept only a generated filename, resolve it against models/, and verify the final path remains inside that directory.

CRITICAL / HIGH **Unsafe PyTorch checkpoint loading**

torch.load() can execute code when loading a malicious checkpoint.

Evidence: qa_engine.py:73
Improve by: Use weights_only=True where supported, validate checkpoint schema and tensor types, and never load untrusted .pth files.

HIGH **Not-found detection is effectively unreachable**

The RRF score is composed of positive terms and is normally above 0.015, so the abstention condition rarely activates.

Evidence: qa_engine.py:155-162
Improve by: Calibrate thresholds using validation data and combine dense similarity, lexical overlap, and top-result margin checks.

HIGH **Confidence scores are not trustworthy**

Cosine similarity is linearly mapped to confidence, while conversational responses use hard-coded 0.98/0.99 values.

Evidence: qa_engine.py:160-194; api/index.py:134-192
Improve by: Calibrate confidence on labeled answerable and unanswerable examples, then return confidence bands or calibrated probabilities.

HIGH **The model is not genuinely generative**

The answer head predicts only the first answer token during training and is not used during inference. Answers are produced by retrieval and rule-based sentence synthesis.

Evidence: trainer.py:169-174; qa_engine.py:208-300
Improve by: Implement sequence generation with teacher forcing and decoding, or describe the system honestly as retrieval plus extractive synthesis.

HIGH **Hosted deployment contradicts the offline claim**

The Vercel demo is cloud-hosted while the interface and documentation present a 100% offline claim.

Evidence: README.md; api/index.py:1-3
Improve by: Label local mode as offline and hosted mode as cloud/demo mode. Do not mark cloud requests as offline.

HIGH **Unbounded request bodies**

Content-Length is trusted and the complete request body is loaded into memory, allowing oversized payloads.

Evidence: api/index.py:118-121; gui_server.py:888-890
Improve by: Reject requests over a fixed limit before reading them and enforce separate PDF and JSON limits.

MEDIUM **CORS allows every origin**

The API sends Access-Control-Allow-Origin: *.

Evidence: api/index.py:46-48
Improve by: Restrict CORS to the known frontend origin or remove CORS for local-only use.

MEDIUM **Study-aid input validation is bypassed**

validate_passage() is imported but not applied before processing.

Evidence: api/index.py:18 and study-aid handler
Improve by: Validate input type, word count, maximum characters, and empty values server-side.

MEDIUM **Broad exception handling**

Broad catches hide operational failures and one endpoint returns internal exception details to clients.

Evidence: api/index.py:33 and 217-230
Improve by: Log errors server-side, return safe public messages, and preserve clear error categories.

MEDIUM **Concurrent training can corrupt shared state**

Multiple requests can overwrite uploaded_model.pth and update the global QA runner at the same time.

Evidence: api/index.py:251-256; gui_server.py:23-45
Improve by: Use per-job temporary directories, atomic model replacement, and a training lock or queue.

MEDIUM **No proper evaluation dataset**

Tests primarily check keywords and basic response structure; they do not measure retrieval accuracy, hallucination, citation correctness, or abstention quality.

Evidence: tests/test_pdf_qa_grounded.py:90-152
Improve by: Add answerable, unanswerable, adversarial, multilingual, and citation-correctness cases. Track precision, recall, F1, abstention accuracy, and calibration error.

MEDIUM **Synthetic questions may create false labels**

Regex-generated questions can produce weak or incorrect QA pairs from sentence patterns.

Evidence: data_loader.py:416+
Improve by: Validate and deduplicate generated pairs and allow human review before training.

LOW **Telemetry is partly simulated or estimated**

The deterministic engine sleeps for 0.4 seconds and token counts are heuristic, so reported latency and throughput are not actual model measurements.

Evidence: engine.py:140; metrics.py:21-30
Improve by: Label simulated metrics explicitly and use the actual tokenizer and runtime for benchmarks.

LOW **Tests write generated files into the repository**

Interrupted tests can leave PDFs, JSON files, and model checkpoints behind.

Evidence: test_neural_trainer.py:17-33
Improve by: Use tempfile.TemporaryDirectory() and guaranteed teardown.

Recommended improvement order

1. Secure upload, training, path handling, and checkpoint loading.
2. Fix retrieval abstention and confidence calibration.
3. Clarify the architecture and remove unsupported generative/offline claims.
4. Add request validation, concurrency control, and safe error handling.
5. Build a real evaluation benchmark for answer accuracy and hallucination prevention.
6. Replace simulated telemetry with measured runtime metrics.

Validation status

The repository test suite completed successfully with 14 tests passing. This result is not sufficient evidence that the security and quality issues above are resolved, because the current tests do not exercise the vulnerable paths or measure the required quality thresholds.

Prepared from the repository review of AI-for-Inclusive-Education-Offline-Smart-Learning-Assistant. File references point to the reviewed source locations.